PrintNightmare · Windows Print Spooler

CVE-2021-34527 | De-identified public edition | Published 2026-11-09

Record	Scope
Evidence	Observed in lab
Lab record date	2026-11-09
Environment	Windows Server 2008 R2 SP1 · Host-only lab
Evidence scope	SYSTEM shell recorded on the Windows target
Patch verification	No patch retest recorded

Public summary: evidence is transcribed and de-identified. Original reports and screenshots are retained locally.

專題目標與範圍

這份專題以 CVE-2021-34527（PrintNightmare）為主題，整理 Windows Print Spooler 的服務確認、驅動程式載入與執行身分驗證。實驗使用 Kali Linux 與 Windows Server 2008 R2 SP1 靶機，流量限制於隔離的 Host-only 網路。

2026 年 11 月 9 日的本機報告與截圖，保留了 Windows 目標上的 SYSTEM Shell。公開版本以服務角色描述環境，移除 IP、主機名稱、帳號與認證資料。

從服務條件走到執行結果

Microsoft 的 CVE 公告 將此問題列為 Windows Print Spooler 遠端程式碼執行弱點。本專題的重點，是區分服務可連線、RPC 可綁定、載入流程及目標執行身分，逐步建立結論。

階段	現有紀錄支持的觀察
服務確認	掃描與 RPC 列舉紀錄包含 Print Spooler 線索
遠端介面	保留了遠端 spoolss 管道綁定結果
目標環境	使用舊版 Windows Server 測試平台
執行結果	回連終端中的身分查詢顯示 SYSTEM

實測證據摘要

成功畫面中的核心身分檢查如下；公開轉錄省略回連位址與主機識別資訊：

```
C:\Windows\system32>whoami
nt authority\system
```

這份結果支持目標上存在 SYSTEM 執行環境。現有公開佐證沒有一般帳號與管理員帳號的完整對照，因此不延伸為「已驗證所有低權限認證情境」。

錯誤訊息與成功證據的差別

實驗紀錄出現過 STATUS_PIPE_BROKEN。這是連線或服務狀態的線索，單靠它不足以證明漏洞已成功利用，也不能直接確定當機原因。本次成功結論依據的是另外保留的目標終端與身分回應。

舊版 Windows 的驅動程式路徑與檔案鎖定，也讓「照著範例執行」和「理解實際環境」之間產生差距。這份紀錄留下的學習重點，是把平台條件、服務行為與可觀察證據拆開確認。

修補方向與後續複測

修補版本必須依實際作業系統及官方公告選擇，不能把其他 Windows 版本的單一 KB 號碼直接套用到本靶機。除適用的安全更新，也應檢視非必要的列印服務與網路存取。

Microsoft 後續調整 Point and Print 的預設驅動程式安裝行為，要求管理員權限；這項設定與相關更新需要依環境一併檢查。MSRC：Point and Print 預設行為變更

目前紀錄未包含修補後複測。後續應保留更新與設定狀態，重新比較服務可達性、驅動程式安裝限制及目標行為，避免以單次 SYSTEM 結果取代完整防護驗證。